

Priorização de vulnerabilidades

Seminário de análise de artigo científico

Claudio Meireles

Projeto Capstone I · IDP · 2026.2

Recorte provisório do TCC

Área

Cibersegurança

Recorte do seminário

Avaliação de critérios para priorizar vulnerabilidades

Pergunta inicial

Como a escolha do escore altera a lista de correções prioritárias?

Seleção: busca e triagem

- 1 Acesso CAFe pelo IDP e abertura da ACM Digital Library
- 2 Busca proposta: "vulnerability prioritization" AND (CVSS OR EPSS OR SSVC)
- 3 Filtro inicial: 2021–2026, artigo completo, pesquisa empírica
- 4 Leitura integral e decisão por aderência, método e dados

Artigo selecionado

Conflicting Scores, Confusing Signals: An Empirical Study of Vulnerability Scoring Systems

Viktoria Koscinski, Mark Nelson, Ahmet Okutan,
Robert Falso e Mehdi Mirakhorli

ACM CCS 2025 · Artigo completo · p. 1904–1918

Originalidade: dados e análises próprios sobre sistemas de pontuação

Relevância para o meu TCC

Critério	Evidência	Uso possível no TCC
Aderência	Priorização de correções	Problema de defesa mensurável
Pesquisa empírica	600 CVEs e 4 sistemas	Referência de desenho comparativo
Reprodutibilidade	Dados e scripts públicos	Inspeção e replicação parcial
Atualidade	Publicação em 2025	Base recente, com dados de 2024

Métricas da conferência

Indicador	Resultado verificado
CORE / ICORE 2026	A*
Qualis Eventos · 2017–2020	A1 · lista oficial da CAPES
Regra de enquadramento por h5	A1 quando $h5 \geq 35$
h5 histórico · lista provisória de 2019	77 · não representa o valor atual
h5 atual · Google Scholar	Consulta bloqueada · confirmação pendente

Mapa da estrutura do artigo

Elemento	Localização na versão lida
Título, autoria, resumo e palavras-chave	Página 1
Introdução e fundamentos	Seções 1–2
Metodologia	Seção 3 · Case Study Setup
Resultados por pergunta de pesquisa	Seção 4 · RQ1–RQ4
Ameaças à validade e discussão	Seções 5–6
Trabalhos relacionados e conclusões	Seções 7–8
Referências e análises complementares	References · Apêndices A–B

Título, resumo e indexação

Título

Problema em destaque e subtítulo que identifica o estudo empírico

Resumo

Problema, método e amostra. Resultados descritos sem efeito numérico central.

Autoria e indexação

Afiliações, palavras-chave e conceitos ACM identificam e tornam o trabalho recuperável



Introdução e fundamentos

Sistema	O que representa no estudo
CVSS	Severidade técnica da vulnerabilidade
EPSS	Probabilidade de exploração nos próximos 30 dias
SSVC	Ação sugerida conforme contexto e impacto
Exploitability Index	Estimativa baseada em modelo e histórico do produto

Metodologia e unidades de análise

Conjunto	Dimensão e papel
Estudo principal	600 CVEs · Microsoft · abril–julho de 2024
Comparação com EPSS disponível	458 CVEs · 142 sem escore no retrato de 09/07/2024
Análise temporal adicional	1.226 CVEs do KEV · retratos mensais de 2021–2024
Instrumentos	Correlação, concordância, faixas de escore e top-N

Ausência de escore não equivale a escore zero. Os conjuntos respondem a análises diferentes.

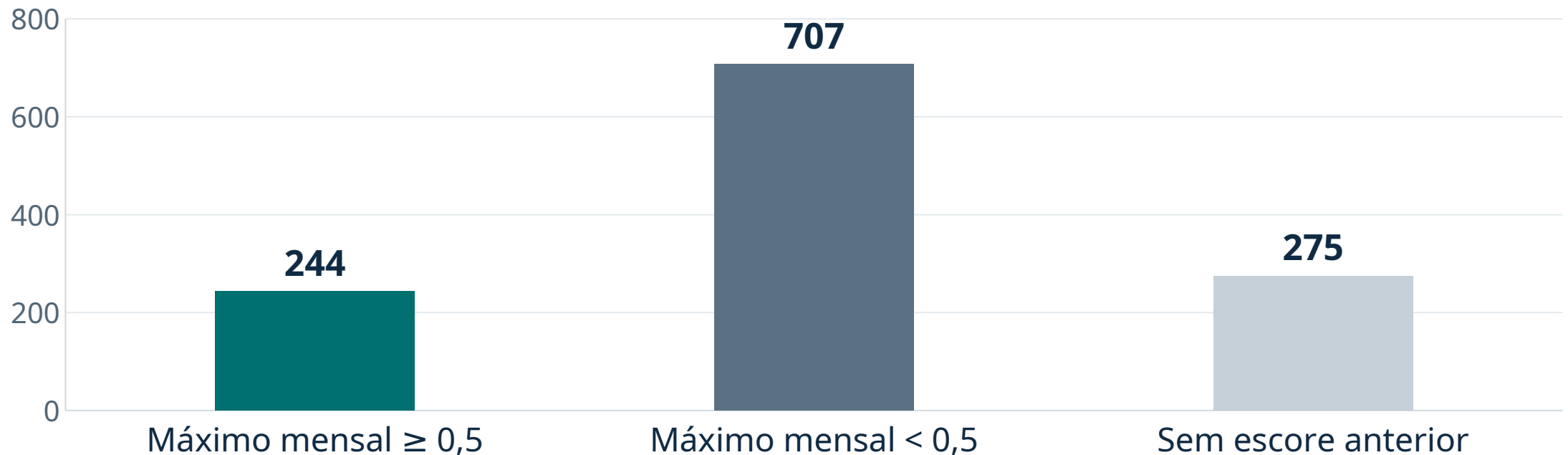
Resultados organizados pelas perguntas

Pergunta	Resultado relatado
RQ1 · Concordância	Kappa próximo de zero nas comparações apresentadas
RQ2 · Triagem	Top-20 do CVSS inclui 198 CVEs com os empates
RQ3 · Exploração conhecida	Escore baixos ou ausentes motivam a análise temporal
RQ4 · Classes CWE	Poucos casos em muitas classes limitam generalizações

EPSS antes da inclusão no KEV

244 de 1.226 · 19,9%

atingiram EPSS $\geq 0,5$ em algum retrato mensal anterior à inclusão



Derivação: $707 = 1.226 - 244 - 275$. Proporção na amostra, não acurácia. Fonte: §4.3.2 e Tabela 6.

Discussão, limites e conclusão

Discussão dos autores

Escores precisam ser interpretados junto ao contexto da organização

Minha análise crítica

Escalas distintas, recorte Microsoft e observação temporal limitam as conclusões

Conclusão e sustentação

Síntese das RQs. Trabalhos relacionados posicionam a contribuição. Referências e apêndices permitem conferência.

Aproveitamento possível no TCC

Pergunta possível

Com o mesmo limite de correções, como diferentes critérios alteram a seleção de CVEs?

Desenho inicial

Comparação temporal com dados públicos, regras explícitas e controle de dados ausentes

Próxima decisão

Revisão de literatura e piloto para delimitar contribuição e viabilidade

Referências principais

- 1 Koscinski et al. (2025). Conflicting Scores, Confusing Signals. ACM CCS. DOI: 10.1145/3719027.3765210.
- 2 CAPES. Relatório Qualis Eventos 2017–2020 e Relatório de Avaliação 2021–2024 da área de Computação.
- 3 CORE Conference Portal. ICORE 2026. Consulta: 15/09/2026.
- 4 FIRST. EPSS Frequently Asked Questions.
- 5 Oliveira, Patrícia. Projeto Capstone I. Aulas 11, 12, 13 e 14.